

FortiOS Administration

1.) Deployment & System Configuration

a) Initial Setup: Factory default settings, interface roles, administrative protocols (HTTPS, SSH, PING, FMG-Access). b) Administrative Access & Security: Custom admin profiles, RBAC permissions, and Trusted Hosts constraints. c) System Maintenance: Backup/restore of system configurations, firmware upgrade paths, and use cases. d) Network Services: Configuring FortiGate as a DHCP server, scope reservations, and lease monitoring. e) Licensing: FortiCare registration and FortiGuard contract validation.

1.) Deployment & System Configuration

a) Initial Setup

- Factory Default Settings:
 - Entry-level FortiGate models run a DHCP server on port1 or the internal switch ports by default (allocating IP addresses in the 192.168.1.0/24 subnet) with a default management IP of 192.168.1.99. Mid-range and high-end models utilize a dedicated mgmt interface.
 - The factory default login credentials are username admin with a blank password. Upon initial login via HTTPS (<https://192.168.1.99>), FortiOS forces an immediate password change before granting access.
- Interface Roles: Interfaces can be categorized with explicit roles: LAN, WAN, DMZ, or Undefined. Applying a WAN or LAN role automatically activates Link Layer Discovery Protocol (LLDP) to dynamically detect upstream or downstream Security Fabric devices.
- Administrative Protocols: Access protocols must be explicitly enabled on a per-interface basis under the allowaccess configuration:
 - HTTPS: Encrypted Web GUI access.
 - SSH: Encrypted Command-Line Interface (CLI) access.
 - PING: Responds to ICMP Echo Requests for physical/logical reachability testing.
 - FMG-Access: Dedicated communication channel for central management via FortiManager.
 - Security Fabric Connection: Enables CAPWAP and FortiTelemetry for coordination between Security Fabric nodes, managed FortiSwitches, and FortiAPs.

b) Administrative Access & Security

- Custom Administrator Profiles (`config system accprofile`): Implements Role-Based Access Control (RBAC). Permissions for individual modules (Firewall, VPN, UTM, Logs) can be granularly set to Read-Write, Read-Only, or None. The default `super_admin` profile bound to the `admin` account is hardcoded and immutable.
- Trusted Hosts Constraints: Restricts administrator logins to specific IP addresses or subnets (`trusthost1`, `trusthost2`) per admin account.
 - *Critical SNAT Warning*: If administrative traffic passes through an intermediate gateway performing Source NAT (SNAT), FortiGate evaluates the translated NAT IP address rather than the client's original private IP.
- Idle Timeout: Configures global or profile-level inactivity timers that automatically terminate administrative GUI/CLI sessions after a set period (default is 5 minutes).

c) System Maintenance

- Configuration Backup & Restore:
 - FortiGate configurations are stored as plain-text CLI scripts. Backups can be saved locally or encrypted with a password.
 - When restoring a backup file across different models or firmware versions, interface syntax and hardware definitions must be manually audited to avoid boot errors.
- Firmware Upgrade Paths:
 - Upgrades must strictly follow the official Fortinet Upgrade Path Tool. Skipping intermediate releases can corrupt system databases or disable firewall policies.
 - In High Availability (HA) clusters, firmware updates are managed in-band by the primary unit, which updates backup cluster members first before failing over to preserve uptime.

d) Network Services (FortiGate as a DHCP Server)

- DHCP Operating Modes: FortiGate can function as a local DHCP Server (assigning IP addresses to connected clients) or as a DHCP Relay (forwarding `DHCPDISCOVER` broadcasts across subnets to a remote enterprise server).
- Scope Reservations & MAC Binding: Static IP-to-MAC address bindings can be defined within the DHCP pool to guarantee fixed IP assignments for servers, IP phones, or printers.
- Lease Monitoring: Active DHCP leases can be inspected from the CLI using `diagnose sys dhcp server list`. Advanced DHCP options (Option 3 for Default Gateway, Option 6 for DNS, Option 42 for NTP) are fully supported.

e) Licensing

- FortiCare Product Registration: Validates device ownership, grants technical support entitlements, and unlocks firmware download access.
- FortiGuard Subscriptions: Delivers real-time signature updates for threat prevention engines (Antivirus, Intrusion Prevention, Web Filtering, Application Control, and IP

Reputation). Contract validity and server connectivity can be verified using `diagnose debug rating` or via the GUI System Information widget.

2.) Logging & Monitoring

a) Log Architecture: Log workflow, log categories (Traffic, Event, UTM Security), and severity levels (0–7). b) Log Storage Destinations: Local disk storage vs. remote logging options (Syslog, FortiCloud, FortiAnalyzer). c) FortiAnalyzer Integration: Device registration workflow, upload options (Real-Time vs. Scheduled), and reliable logging (`confirm queue`). d) Analytics: Historical FortiView dashboard requirements and CLI log filtering (`execute log filter`).

2.) Logging & Monitoring

a) Log Architecture

- Log Workflow:
 - Traffic passes through FortiGate to the network.
 - FortiGate scans and acts on traffic based on configured firewall policies.
 - FortiGate records the activity in a structured log message.
 - The log entry is stored in a log file on local storage or transmitted to an external logging device (such as FortiAnalyzer).
 - *NTP Requirement:* Effective logging requires accurate system date and time for timestamp alignment. Fortinet recommends synchronizing with a Network Time Protocol (NTP) server; FortiGate acts as an NTP server by default.
- Log Categories:
 - Traffic Logs: Record details about traffic flows traversing firewall policies, including source, destination, service, IP addresses, and whether the traffic was accepted or denied.
 - Event Logs: Record system and administrative operations. Subtypes include System (GUI logins, automatic FortiGuard updates), User (authenticated policy logins/logoffs), Router, VPN (IPsec and SSL VPN tunnels), WAD, and Wireless.
 - Security Logs (`log type = utm`): Record security events triggered by Unified Threat Management (UTM) profiles. Subtypes include Antivirus, Web Filter, Application Control, IPS, DLP, Email Filter (Antispam), Anomaly (DoS policy), and WAF. *Note: Security log subtypes are visible in the GUI only if matching logs exist on the device.*
- Log Severity Levels (0–7):
 - Log priority ranges from 0 (Emergency) to 7 (Debug).
 - The standard operational level is typically set to Notification (5) or Information (6) to capture accounting events (such as user logins and session states) without overwhelming storage resources.

b) Log Storage Destinations

- Local Disk Logging:
 - Mid-range to high-end FortiGate models with an internal hard drive store logs locally in an SQL database.
 - *FortiView Dependency*: Disk logging must be enabled for historical analytics to display on FortiView dashboards. If disabled, FortiView displays real-time data only.
 - *Retention Default*: Logs older than 7 days are automatically deleted by default (configurable).
 - *WAN Optimization Conflict*: Devices with a single hard drive cannot run WAN optimization and disk logging simultaneously. Dual-disk models can allocate one disk to WAN optimization and the other to local logging.
- Remote Logging Options:
 - Offloading logs externally is preferred to preserve system performance. Supported destinations include FortiAnalyzer, FortiManager, FortiCloud, FortiSIEM, and Syslog servers.
 - *FortiCloud Tiers*: Includes a free tier (7-day log retention) and a paid subscription tier (1-year retention with advanced reporting).

c) FortiAnalyzer Integration

- Device Registration Workflow: FortiGate initiates a registration request to FortiAnalyzer using the Fabric Connector (**Security Fabric > Fabric Connectors > Logging & Analytics**), which must then be authorized on FortiAnalyzer's Device Manager tab.
 - Upload Options:
 - Real Time: Transmits logs immediately as they are generated.
 - Every Minute / Every 5 Minutes (Default): Batches log transmissions to optimize link bandwidth.
 - Store-and-Upload (CLI Only): Available only on models with an internal hard drive. Stores logs locally on disk and uploads them to FortiAnalyzer at a scheduled low-bandwidth time (**config log fortianalyzer setting \(\rightarrow\) set upload-option store-and-upload**).
 - Reliable Logging (**confirm queue**):
 - When both FortiGate and FortiAnalyzer run FortiOS 7.2 or later with reliable logging enabled, FortiGate retains sent logs in a confirm queue.
 - FortiGate tracks entries using sequence numbers (**seq_no**) and clears logs from the queue only after receiving confirmation of successful receipt from FortiAnalyzer.
-

d) Analytics & Searching

- Historical FortiView Requirements: Requires disk logging or a remote collector (FortiAnalyzer/FortiCloud) to index historical trend data.
- GUI Filtering & Quick Filters: Logs can be searched using custom column filters or by right-clicking any cell entry in a log table to create an instant quick filter on that specific attribute (e.g., filtering all traffic matching a specific source IP or Web Filter category).

CLI Log Interrogation:

1. Clear previous display filters

execute log filter reset

2. Set category (e.g., category 1 = Traffic, 3 = Security/UTM)

execute log filter category 1

3. Apply field filter

execute log filter field srcip 10.0.11.253

4. Display matching log entries

execute log display

3.) Firewall Policies & Session Handling

a) Policy Setup: Configuring IPv4/IPv6 rules, interface pairs, address objects, and Internet Service Database (ISDB) objects. b) Rule Evaluation Logic: Sequential top-to-bottom matching order, first-match termination, and the Implicit Deny policy. c) Session Tracking: Stateful connection table mechanics and return reply traffic handling. d) Inspection Modes: Flow-based (IPS pattern-matching on-the-fly) vs. Proxy-based (socket termination, file buffering, and quotas). e) Special Policies: Local-in policies (control-plane security), DoS policies, Multicast, and Virtual Wire Pairs.

3.) Firewall Policies & Session Handling

a) Policy Setup & Objects

- Core Policy Components: Firewall policies control transient traffic flowing *through* the FortiGate. Each rule defines matching criteria including Incoming Interface, Outgoing Interface, Source Address, Destination Address, Schedule, and Service.
- Address Objects:
 - Subnet / IP Range: Standard IPv4/IPv6 host or subnet definitions.
 - FQDN (Fully Qualified Domain Name): Resolves domain names to IP addresses dynamically via DNS queries.
 - Wildcard Subnet: Matches non-contiguous subnets or specific IP bit patterns.
 - Geography: Matches traffic originating from or destined to specific countries based on the FortiGuard IP location database.
- Internet Service Database (ISDB) Objects: Dynamic, predefined database objects managed by FortiGuard. They combine IP addresses, protocols, and transport port numbers associated with popular cloud and web services (e.g., Microsoft Office 365, AWS, Salesforce).
- The **any** Interface Rule: If an interface field (incoming or outgoing) is set to **any**, you cannot select multiple individual interfaces in that same field, as **any** already implies all physical and logical interfaces.

b) Rule Evaluation Logic & Views

- Sequential Top-to-Bottom Processing: FortiGate evaluates security policies in a strict top-to-bottom sequence. Evaluation stops immediately on the first complete match.
- Implicit Deny Policy: Placed hardcoded at the very bottom of the policy list. Any packet that fails to match an explicit policy hits the implicit deny rule and is dropped.
 - *Logging Gotcha*: By default, the implicit deny policy does not log dropped traffic. Violation logging must be explicitly enabled on the implicit deny rule or viewed via diagnostic packet traces.
- Policy IDs: Every rule is assigned a static, numeric Policy ID. The Policy ID serves purely as an internal database index key and never changes, even if the policy is moved higher or lower in the processing order.
- Policy Views:
 - Interface Pair View (Default): Groups policies strictly by ingress-to-egress interface pairings.
 - By Sequence: Merges all policies into a single flat list ordered by exact kernel evaluation sequence. This view is mandatory when policies utilize the **any** interface or multiple interface targets.
 - Sequence Grouping View: Displays policies as a flat list under custom organizational labels.

c) Stateful Session Mechanics

- **Stateful Firewall Architecture:** FortiGate tracks the state of active network connections in its kernel session table.
- **Directionality & Reply Traffic:** Firewall policies only need to match the direction of the traffic that initiates the connection. Once approved, FortiGate automatically creates a bi-directional session entry, allowing return reply traffic to pass without requiring a reverse policy rule.
- **Two Lookups per Session:** The routing and security engine performs route lookups on only the first request packet and the first reply packet of a session. Subsequent packets matching that active session bypass policy evaluation and are forwarded directly based on session table state.

d) Inspection Modes (Flow-Based vs. Proxy-Based)

Administrators can select the inspection mode per policy depending on performance and security requirements:

Operational Feature	Flow-Based Inspection (Default)	Proxy-Based Inspection
Mechanics	Inspects content on-the-fly packet-by-packet using IPS engine pattern matching.	Acts as a transparent proxy; terminates client socket, buffers full files, and opens a 2nd socket.
Performance	Low latency, high throughput; hardware-accelerated by SPU (CP8/CP9) & NTurbo.	Higher latency and higher memory (RAM) utilization due to payload buffering.
Block Pages	Replacement block pages cannot be displayed mid-stream if a threat is detected late.	Always guarantees full, clean replacement block pages to the user.
Advanced Features	Basic profile options (Antivirus, Web Filtering, Application Control, IPS).	Advanced features: usage quotas, proxy web profile overrides, CDR, and MAPI/SSH inspection.

e) Specialized Firewall Policies

Beyond standard transient IPv4/IPv6 policies, FortiOS supports specialized policy types (enabled via Feature Visibility):

- Local-In Policy: Controls traffic destined directly to a FortiGate interface IP (control-plane traffic such as administrative GUI/SSH access, IPsec VPN tunnels, and BGP peering).
 - DoS Policy: Inspects raw packets arriving on an interface for anomalous volume floods (e.g., SYN floods, ICMP sweeps) to block denial-of-service attacks before full policy processing.
 - Virtual Wire Pair Policy: Regulates traffic moving between two explicitly paired physical or logical interfaces operating as a Layer 2 bridge.
 - Multicast Policy: Explicitly permits and forwards multicast streams across interfaces.
-

4.) Network Address Translation (NAT)

a) Source NAT (SNAT): Port Address Translation (PAT) using the primary Outgoing Interface Address. b) Dynamic IP Pools: Standard **overload**, **one-to-one**, **fixed-port-range** (carrier-grade), and **port-block-allocation**. c) Destination NAT (DNAT / VIPs): Virtual IP objects, public-to-private server mapping, and Port Forwarding. d) Outbound VIP SNAT: Automatic 1-to-1 VIP outbound translation behavior and its dependency on active inbound policy references. e) Central SNAT vs. Policy-Based NAT: Managing translation rules globally in **central-snat-map** vs. directly within individual firewall policies.

4.) Network Address Translation (NAT)

a) Source NAT (SNAT)

- Firewall Policy SNAT: Translates the source IP address (and optionally source port) of egress traffic as it leaves the FortiGate [cite: 5].
- Use Outgoing Interface Address:
 - Translates the private source IP of matching internal packets to the primary IP address assigned to the outgoing (egress) interface [cite: 7].
 - Performs Port Address Translation (PAT) / many-to-one translation by assigning unique port numbers from an available pool to differentiate client connections sharing the single public interface IP [cite: 7, 8].
- Fixed Port Option:
 - Disables source port translation during PAT [cite: 8].
 - *Constraint:* If multiple internal clients attempt to initiate connections requiring the exact same source port to the same external target IP and service, only one connection succeeds; subsequent connections fail due to a session collision [cite: 8].

b) Dynamic IP Pools

When NAT requires mapping private subnets to a range of public addresses distinct from the egress interface IP, administrators configure IP Pools (**Policy & Objects > IP Pools**) [cite: 7, 9].

- IP Pool Types:
 1. Overload (Default): Maps multiple private internal IPs to a range of public IPs using many-to-one / many-to-few PAT [cite: 10, 11].
 2. One-to-One: Assigns public IP addresses from the pool to internal hosts on a strict first-come, first-served basis [cite: 11, 12]. No port translation occurs [cite: 12]. *Packets from unserved internal hosts are dropped if the pool runs out of addresses* [cite: 11, 12].
 3. Fixed Port Range: Disables port translation across a defined range of IPs; commonly used in Carrier-Grade NAT (CGN) environments [cite: 10, 54].
 4. Port Block Allocation: Assigns discrete blocks of transport ports to specific internal subscriber IPs to streamline NAT logging overhead in CGN deployments [cite: 10, 54].
- *IP Pool Routing Requirement*: If the addresses in an IP pool belong to a subnet different from the address assigned to the physical egress interface, appropriate routing must be established on upstream routers to direct return traffic back to the FortiGate [cite: 9].

c) Destination NAT (DNAT) & Virtual IPs (VIPs)

- Virtual IP (VIP) Objects: Represent inbound Destination NAT rules (**Policy & Objects > Virtual IPs**). A VIP maps an external public IP address/port to an internal private server IP address/port [cite: 5, 13].
- Static 1-to-1 Mapping: By default (with Port Forwarding disabled), a VIP creates a static 1-to-1 destination mapping for all incoming ports and protocols [cite: 13, 15].
- Port Forwarding: When Port Forwarding is enabled on a VIP, FortiGate redirects incoming sessions matching an external port (e.g., public port **8080** or **222**) to a different mapped internal port (e.g., private port **80** or **22**) [cite: 14, 17, 18]. This enables multiple internal hosts to share a single external IP address on different public listening ports [cite: 14, 17].
- FQDN Type VIPs: Allows selecting FQDN address objects for external/internal destinations, enabling FortiGate to dynamically update VIP translation tables when DNS resolutions change [cite: 13].
- ARP Reply: Enabled by default on VIPs. FortiGate automatically responds to ARP requests from upstream ISP routers for the public IP address defined in the VIP [cite: 16, 19].

d) Outbound VIP SNAT Behavior

- Automatic Outbound Translation: When an internal server mapped by a static 1-to-1 VIP initiates an *outbound* connection (e.g., a DMZ mail server sending an outbound email),

FortiGate automatically translates the server's source IP to the VIP's external IP address instead of using the egress interface's IP [cite: 13, 16].

- **CRITICAL EXAM GOTCHA (Inbound Policy Dependency):** Automatic outbound VIP translation occurs only if an active inbound firewall policy references that VIP object as its destination [cite: 17]. If no inbound policy references the VIP, or if that policy is disabled, outbound traffic falls back to using the egress interface address or configured IP Pool [cite: 17, 18].

e) Central SNAT vs. Policy-Based NAT

Operational Attribute	Policy-Based NAT (Default Mode)	Central Source NAT (Central SNAT)
Mapping Mechanism	SNAT rules are defined directly within each individual firewall policy [cite: 5, 49].	SNAT translation rules are managed in a decoupled global table (<code>central-snat-map</code>) [cite: 48, 49].
CLI Activation	Enabled out of the box [cite: 49].	Must be explicitly enabled: <code>config system global \(\rightarrow\) set central-nat enable</code> [cite: 49].
Decoupling	Security policy and address translation are coupled together [cite: 49].	Firewall policies define access permissions; Central SNAT policies govern IP translations [cite: 48, 49, 56].
Order of Operations	Firewall policy matches first \(\rightarrow\) SNAT inside policy executes.	Inbound DNAT (VIP) occurs FIRST \(\rightarrow\) Route & Policy evaluation (matching post-DNAT private IP) \(\rightarrow\) Central SNAT matches upon egress [cite: 52].

- **FortiOS 7.6.1+ Upgrade Rule:** Starting in FortiOS 7.6.1, individual SD-WAN member interfaces can no longer be directly selected as egress targets in central SNAT rules (selection is restricted to physical non-SD-WAN ports or whole SD-WAN Zones) [cite: 50]. To map specific IP pools to individual member interfaces within a zone,

administrators must use the `associated-interface` parameter under IP Pool settings via the CLI [cite: 51].

5.) Routing & Forwarding

a) Route Lookup Precedence: Route resolution occurring *before* firewall policy and SNAT evaluation. b) RIB vs. FIB Databases: Routing Information Base (control plane) vs. Forwarding Information Base (kernel data plane). c) Static Routing & Tiebreakers: Destination prefix length, Administrative Distance (protocol priority), and Priority (static route tiebreaker). d) Equal-Cost Multi-Path (ECMP): Load balancing algorithms (Source IP, Source-Destination IP, Weighted, and Spillover). e) Policy-Based Routing (PBR): Matching traffic by source subnet, protocol, and port, with absolute precedence over standard FIB entries. f) SD-WAN: SD-WAN zones, link health performance monitors (SLA targets), and dynamic application steering rules.

5.) Routing & Forwarding

a) Route Lookup Precedence

- **Routing Before Security:** In FortiOS, route lookup occurs before firewall policy evaluation, UTM content inspection, traffic shaping, and Source NAT (SNAT) [cite: 111]. FortiGate must resolve the egress (outgoing) interface via a route lookup before it can identify which security policy to evaluate [cite: 111].
- **Session Table Shortcuts:** FortiGate performs exactly two route lookups per session:
 - For the initial packet sent by the originator [cite: 112].
 - For the first reply packet returned by the responder [cite: 112].
 - Once resolved, path parameters are written into the kernel session table [cite: 112]. All subsequent packets in that connection bypass routing engine lookups entirely [cite: 112].
 - *Routing Change Flush:* If a routing table update occurs (e.g., link failover or dynamic route withdrawal), FortiGate immediately flushes affected session table entries to force fresh route lookups [cite: 112].

b) RIB vs. FIB Databases

- **Routing Information Base (RIB):** The control plane database containing all active, connected, static, and dynamic routes learned by the system [cite: 113]. RIB entries are viewable in both the GUI (`Network > Static Routes` / Routing Monitor) and CLI (`get router info routing-table all`) [cite: 113, 122].
- **Forwarding Information Base (FIB):** The kernel data plane table containing the active forwarding paths compiled from the RIB [cite: 113]. When FortiGate forwards a packet, it queries the FIB [cite: 113].

- *CLI Requirement:* The FIB can be displayed strictly via the CLI using `get router info kernel` [cite: 113, 122].
- Standby & Inactive Routes: Routes with higher Administrative Distances than the active primary path are held in the routing table database (`get router info routing-table database`) as standby routes and are promoted to the RIB only if the primary route fails [cite: 114, 123].

c) Static Routing & Tiebreaker Logic

When evaluating routes to a destination, FortiGate applies tiebreakers strictly in sequence [cite: 119]:

1. Longest Prefix Match (Subnet Mask): The most specific destination prefix always wins (e.g., `/24` takes precedence over `/16` or `/0`) [cite: 111, 119].
2. Administrative Distance (AD): Compares trust levels across different route sources (lowest AD wins) [cite: 116, 119]:
 - Connected: `0` (Immutable) [cite: 117]
 - SD-WAN Static: `1` [cite: 117]
 - DHCP Static: `5` [cite: 117]
 - Manual Static: `10` [cite: 117]
 - EBGp: `20` [cite: 117]
 - OSPF: `110` [cite: 117]
 - IS-IS: `115` [cite: 117]
 - RIP: `120` [cite: 117]
 - IBGP: `200` [cite: 117]
3. Metric: Used by dynamic routing protocols (lowest metric wins) [cite: 118, 119].
4. Priority: Tiebreaker for static routes [cite: 118, 119].
 - *Critical Exam Behavior:* If two duplicate static routes have the same AD but different priorities, both routes are installed in the routing table (RIB) [cite: 118, 124]. However, traffic lookup actively prefers the route with the lowest priority value [cite: 118, 124].

d) Equal-Cost Multi-Path (ECMP)

- ECMP Installation: When multiple static or dynamic routes to the exact same destination share identical AD, Metric, and Priority values, FortiGate installs all of them into the active routing table to distribute traffic [cite: 115, 118].
- Load-Balancing Algorithms (`config router settings`):
 - Source IP (Default): Pinning sessions from the same source IP to a consistent path [cite: 115].
 - Source-Destination IP: Pinned based on the unique source/destination IP pair [cite: 115].

- Weighted: Sessions are distributed proportionally based on custom weights configured on static routes or interfaces [cite: 115].
- Spillover (Usage): Directs all sessions to the primary link until its egress bandwidth threshold is reached, spilling extra sessions over to secondary links [cite: 115].

e) Policy-Based Routing (PBR) & ISDB Routes

- Policy Routes (`config router policy`): Overrides destination-only routing by matching traffic on ingress interface, source/destination IP, protocol, and transport port ranges [cite: 116, 121].
- Precedence Rule: Active policy routes take absolute precedence over standard FIB entries and SD-WAN rules [cite: 116, 124].
- *FIB Matching Requirement (Exam Trap)*: For a policy route with action `forward-traffic` to be valid, its destination and gateway must match an existing route in the FIB [cite: 124]. If no FIB route exists for that path, the policy route is flagged as invalid and skipped [cite: 124].
- Internet Service Database (ISDB) Routes: Dynamic routes targeting cloud services (e.g., Office 365, AWS). Although managed under static routing menus, ISDB routes are processed directly in the policy routing table [cite: 111, 124].

f) Software-Defined WAN (SD-WAN)

- SD-WAN Zones: Logical groupings of multiple physical WAN member interfaces (e.g., `virtual-wan-link`, `Underlay_Zone`, `Overlay_Zone`) simplifies policy creation.
- Performance SLA / Link Health Monitors: Probes (Ping, HTTP, DNS) sent across member interfaces to continuously measure Latency, Jitter, and Packet Loss against defined SLA thresholds.
- SD-WAN Rules: Steer application traffic dynamically using four strategies:
 1. Manual: Directs traffic to a static member preference list.
 2. Best Quality: Automatically selects the member interface with the lowest latency/jitter/loss metrics.
 3. Lowest Cost (SLA): Directs traffic over the lowest-cost link that meets the SLA target; falls back to secondary links if SLA fails.
 4. Maximize Bandwidth (Round Robin): Load balances sessions across all member links that currently meet the SLA criteria.

6.) Firewall Authentication

a) Authentication Types: Active (Captive Portal) vs. Passive silent identity tracking. b) Identity Databases: Local user accounts, user group mapping, and security exempt lists. c) Remote Authentication Servers: LDAP setup (regular bind types, CNIDs, search bases) and RADIUS server packets (`Access-Request`, `Access-Accept`, `Access-Reject`,

Access-Challenge). d) Authentication Timeouts: Hard timeouts vs. idle timeouts in active session tracking.

6.) Firewall Authentication

a) Active vs. Passive Authentication

- Active Authentication: Requires direct interaction from the user [cite: 135].
 - When unauthenticated traffic hits an active authentication firewall policy, FortiGate intercepts HTTP/HTTPS requests and redirects the browser to a Captive Portal login page [cite: 135].
 - The user must explicitly enter valid credentials before traffic is allowed through [cite: 135].
- Passive Authentication: Identifies users silently in the background without prompting them for credentials [cite: 135].
 - Relies on identity mechanisms like Fortinet Single Sign-On (FSSO) or NTLM/Kerberos browser queries [cite: 135].
 - *Policy Order Rule*: Passive authentication policies (FSSO) must always be placed above active authentication policies (Captive Portal) in the firewall policy list [cite: 143]. Otherwise, users will be forced to log in via a captive portal, bypassing silent FSSO processing [cite: 143].

b) Identity Databases & User Groups

- Local Identity Storage: User accounts and passwords created and stored directly in the FortiGate configuration database (`config user local`).
- Remote Identity Servers: FortiGate offloads credential validation to external enterprise servers using standard protocols: LDAP, RADIUS, TACACS+, or PKI / Smartcard Certificates.
- User Group Mapping:
 - Firewall policies enforce access control based on User Groups, not individual user accounts [cite: 138, 140].
 - Remote directory objects (such as Active Directory Organizational Units or Security Groups) must be mapped to a local FortiGate User Group object before referencing them in firewall policies [cite: 138, 140].

c) Remote Authentication Server Mechanics (LDAP & RADIUS)

- LDAP (Lightweight Directory Access Protocol):
 - Bind Types:
 1. Anonymous: No credentials provided; forbidden by default in Microsoft Active Directory.

- 2. Regular: FortiGate uses a dedicated bind DN user account and password to search the directory tree [cite: 138]. Required for Active Directory integration [cite: 138].
 - Common Attributes: Uses Common Name Identifier (CNID) such as **sAMAccountName** (Active Directory) or **uid** (OpenLDAP) to locate user records.
 - Ports: Standard TCP port **389** (LDAP) or encrypted TCP port **636** (LDAPS / LDAP over SSL).
- RADIUS (Remote Authentication Dial-In User Service):
 - Uses a shared secret to encrypt communication over UDP ports **1812** (Authentication) and **1813** (Accounting).
 - RADIUS Response Packet Types:
 1. **Access-Accept** (Type 2): Credentials validated; access granted [cite: 136, 143].
 2. **Access-Reject** (Type 3): Invalid credentials; access denied [cite: 136, 143].
 3. **Access-Challenge** (Type 11): Secondary authentication requested (e.g., 2FA/MFA token code) [cite: 136, 143]. FortiGate intercepts packet type 11 and prompts the user for their token [cite: 136, 143].

d) Captive Portal & Security Exempt Lists

- Captive Portal Enablement: Can be triggered directly on an ingress interface (**Security Exempt List / Admission Control**) or enforced implicitly by adding a User Group to a firewall policy [cite: 135].
- Security Exempt List: Allows specific IP addresses, subnets, or MAC addresses (e.g., printers, IP phones, local servers) to bypass captive portal redirects and traverse the firewall unauthenticated [cite: 135].
- DNS Prerequisite: Unauthenticated clients must be allowed to resolve DNS queries (UDP/TCP port 53) before authentication [cite: 135]. If DNS is blocked prior to login, client browsers cannot resolve domain names or reach the Captive Portal redirect URL [cite: 135].

e) Authentication Timeouts & Diagnostics

- Timeout Mechanics:
 - Idle Timeout: Terminates the authenticated session if no traffic is detected from the client IP for a set duration (default is 15 minutes).
 - Hard Timeout: Forces the user to re-authenticate after a fixed total duration, regardless of ongoing activity.
 - Auth Keep-Alive: Opens a small JavaScript popup in the user's browser that sends periodic pings to FortiGate to prevent idle timeouts while the browser remains open.
- CLI Diagnostic Commands:

Test Remote Server Credentials:

```
diagnose test authserver ldap <Server_Name> <Username> <Password>
```

```
diagnose test authserver radius <Server_Name> pap <Username> <Password>
```

○

Real-time Authentication Daemon Tracing:

```
diagnose debug application fnbamd -1
```

```
diagnose debug enable
```

7.) Fortinet Single Sign-On (FSSO) & SAML

a) FSSO Architecture: Passive Active Directory integration mapping Windows logon events to user IP addresses. b) FSSO Collector Agent Modes: DC Agent Mode (real-time event captures on DCs) vs. Collector Agent Polling (WMI/WinSec). c) Agentless Polling: Direct FortiGate SMB/WinSec event log polling. d) SAML SSO Onboarding: FortiSASE acting as a Service Provider (SP), Identity Provider (IdP) integration, and Proxy Auto-Configuration (PAC) file traffic steering.

7.) Fortinet Single Sign-On (FSSO) & SAML

a) FSSO Architecture & Passive Authentication

- Passive Authentication Mechanics: FSSO silently maps domain users to their current IP addresses and Active Directory (AD) security groups in the background [cite: 32, 135].
- User Experience: Once a user logs into a domain-joined workstation, FortiGate grants network access based on their mapped AD identity without displaying a captive portal login page [cite: 32, 135].
- Event Detection: FSSO monitors Windows Active Directory Domain Controllers (DCs) for successful user logon events (e.g., Event ID 4624 or Kerberos service ticket Event ID 4768).

b) FSSO Collector Agent Modes

When integrating with Active Directory via external Collector Agent software, administrators choose between two operating modes:

- DC Agent Mode (Most Scalable):
 - A lightweight monitoring agent (**dcagent.dll**) is installed directly on every Domain Controller in the domain.

- The DC Agent captures logon events locally in real time and immediately pushes them to the central FSSO Collector Agent.
 - *Pros/Cons*: Highly scalable, minimal network overhead, and avoids polling delay. However, requires a Domain Controller reboot during initial installation.
- Collector Agent Polling Mode (No DC Reboot):
 - The FSSO Collector Agent is installed on a member server and periodically polls the Domain Controllers' Event Logs remotely.
 - Polling Protocols: Uses WMI (Windows Management Instrumentation) over TCP port 135/445 or WinSec (SMB) over TCP port 445.
 - *Pros/Cons*: Requires no installations or reboots on Domain Controllers. However, it increases CPU utilization on DCs and generates higher network polling traffic.

c) Agentless Polling Mode

- Direct Control Plane Polling: FortiGate connects directly to Domain Controllers using SMB/WinSec (TCP port 445) to read event logs without requiring external Windows Collector Agent software [cite: 22].
- Deployment Use Case: Ideal for small-to-medium networks with simple directory structures, as it eliminates external server dependencies.
- *Agentless Limitation*: Does not support workstation checking or complex nested group filtering. If a client's IP changes without triggering a fresh AD logon event, FortiGate will not detect the update [cite: 22].

d) Workstation Checking & Group Filtering

- Workstation Checking (IP Verification):
 - The Collector Agent periodically verifies if authenticated users are still logged into their recorded IP addresses using NetBIOS sweeps (UDP port 139) or WMI checks.
 - If a workstation fails to respond after set retries (e.g., user logged off or disconnected from Wi-Fi), the Collector Agent deletes the IP-to-user mapping and notifies FortiGate to clear the session table entry.
- Group Filtering:
 - Active Directory environments often contain thousands of security groups. To prevent overwhelming FortiGate memory, administrators configure Group Filters on the Collector Agent to import only specific relevant Organizational Units (OUs) or Security Groups.

e) SAML Single Sign-On (SSO)

- SAML Framework: Uses XML assertions over HTTPS to provide federated Single Sign-On across web applications and cloud gateways [cite: 22].
- SAML Roles:
 - Identity Provider (IdP): Validates user identity and issues cryptographic SAML assertion tokens (e.g., Azure AD / Entra ID, Okta, FortiAuthenticator) [cite: 22].

- Service Provider (SP): Consumes SAML assertions to grant network/application access [cite: 22]. FortiGate and FortiSASE act as the Service Provider (SP) [cite: 22].
- FortiSASE Agentless Onboarding: In agentless FortiSASE deployments, traffic is directed to the secure gateway using a Proxy Auto-Configuration (PAC) file [cite: 22]. Users authenticate via SAML SSO against the external IdP [cite: 22].

f) FSSO Diagnostics & Commands

Inspect Active FSSO Users in FortiOS:

```
diagnose debug authd fsso list
```

Flush Active FSSO User Cache:

```
diagnose debug authd fsso clear-logons
```

Real-time FSSO Daemon Tracing:

```
diagnose debug application authd -1
```

```
diagnose debug enable
```

8.) Certificate Operations & SSL/TLS Inspection

a) Public vs. Private CAs: Managing local certificates, CSR generation, and CRL revoking. b) Certificate Inspection: Inspecting SNI headers and server certificates without decrypting payload data. c) Full SSL/TLS Deep Inspection: In-line proxy decryption and re-encryption requiring local private CA certificate deployment on endpoints to prevent browser security warnings.

8.) Certificate Operations & SSL/TLS Inspection

a) Public vs. Private CAs & Certificate Operations

- Certificate Validation Pipeline: Before trusting and establishing connections with a remote SSL/TLS server, FortiGate performs five parallel validation checks against the server's digital certificate [cite: 1, 11]:
 1. CRL Revocation Check: Queries local Certificate Revocation Lists (CRLs) or downloads fresh CRL updates to ensure the certificate's serial number is not revoked [cite: 1].
 2. Issuer CA Possession: Reads the certificate's Issuer field to verify that FortiGate possesses the corresponding Certificate Authority (CA) root or intermediate certificate in its local store [cite: 1].

3. Validity Dates: Verifies that the current system time falls strictly between the certificate's Valid From and Valid To timestamps [cite: 1].
 4. Digital Signature Verification: Validates the cryptographic signature using the CA's public key to confirm that the certificate was signed by a trusted authority and has not been tampered with [cite: 1, 2].
 5. Chain of Trust: Validates the full hierarchy from the server's leaf certificate up through intermediate CAs to the root CA [cite: 11, 23].
- Local Certificate Management: Administrators can generate Certificate Signing Requests (CSRs) directly on FortiGate (**System** > **Certificates**) to be signed by an enterprise internal CA or a public CA [cite: 17, 25].
 - Intermediate / Subordinate CAs: When using a subordinate CA certificate on FortiGate, the entire chain of intermediate certificates must be installed on the firewall [cite: 23]. FortiGate automatically sends the full intermediate chain to client browsers during the TLS handshake, meaning only the top-level Root CA certificate needs to be imported into endpoint browser stores [cite: 23].

b) Certificate Inspection Mode (SSL Certificate-Based Inspection)

- Non-Decrypting Header Inspection: Inspects encrypted traffic without decrypting the payload [cite: 4, 26].
- SNI Header & Certificate Parsing:
 - Extracts the requested hostname from the Server Name Indication (SNI) TLS extension header sent in the client's **ClientHello** packet [cite: 4, 5].
 - If no SNI header is present, FortiGate inspects the returned server certificate's Subject or Subject Alternative Name (SAN) fields [cite: 4, 5].
- Supported Security Profiles: Because payloads remain encrypted, certificate inspection mode can only enforce Web Filtering (domain category blocking) and Application Control [cite: 5].
- Endpoint Compatibility: Does not alter server certificates, triggers zero browser security warnings, and requires no CA certificates installed on endpoints [cite: 26].

c) Full SSL/TLS Deep Inspection (In-line Proxy)

- Man-in-the-Middle Proxy Architecture: FortiGate terminates client connections and acts as an in-line proxy, maintaining two separate SSL sessions: Client-to-FortiGate and FortiGate-to-Server [cite: 6, 26].
- Payload Decryption & Resigning: Decrypts transient packets in memory, submits clear-text payloads to active security engines (Antivirus, IPS, Web Filtering, DLP), and re-encrypts the stream on the fly using a dynamically generated server certificate signed by FortiGate's local CA [cite: 6, 7, 16].
- Mandatory CA Extensions: To dynamically issue and resign temporary server certificates, the CA certificate used by FortiGate must explicitly contain two X.509 extensions [cite: 16, 17]:
 - **cA = True**: Identifies the certificate as a valid Certificate Authority [cite: 16, 17].

- **keyUsage = keyCertSign**: Grants permission for the corresponding private key to sign child certificates [cite: 16, 17].
- Default CA (**Fortinet_CA_SSL**): Out of the box, FortiGate uses the self-signed **Fortinet_CA_SSL** certificate [cite: 7, 14]. Because endpoint browsers do not trust **Fortinet_CA_SSL** by default, end users will experience severe browser security warnings unless **Fortinet_CA_SSL** (or an enterprise subordinate CA certificate imported onto FortiGate) is deployed to client trusted root stores [cite: 13, 14, 22].

d) Handling Invalid & Untrusted SSL Certificates

FortiGate categorizes remote server certificate failures into four main states: Expired, Revoked, Validation Timeout, or Validation Failed [cite: 10]. In custom inspection profiles, administrators configure specific handling actions for untrusted certificates [cite: 8, 11]:

- Keep Untrusted & Allow (Default): Generates a temporary certificate signed by FortiGate's built-in **Fortinet_CA_Untrusted** certificate [cite: 11, 13]. This deliberately triggers an untrusted site warning in the client's browser, allowing the user to decide whether to proceed [cite: 12, 13].
- Block: Immediately drops the connection if an untrusted or invalid server certificate is encountered [cite: 11, 14].
- Trust & Allow / Ignore: Generates a valid temporary certificate signed by **Fortinet_CA_SSL**, masking server certificate errors and allowing the connection without browser warnings [cite: 11, 14].

e) SSL Exemptions, HSTS & Certificate Pinning

- Exemption Use Cases: Deep inspection must frequently be bypassed due to legal privacy requirements or application breaking [cite: 9]:
 - Legal & Privacy Categories: Predefined categories such as Finance and Banking and Health and Wellness are excluded by default in **deep-inspection** profiles [cite: 9, 10].
 - HTTP Strict Transport Security (HSTS): Websites enforcing HSTS refuse to load if a proxy substitutes their certificate [cite: 9].
 - Certificate Pinning: Applications with hardcoded certificate hashes (e.g., Dropbox, Microsoft Office 365, Skype) break under full SSL inspection because the server certificate signature changes [cite: 18, 19, 20].
 - Exemption Mechanisms:
 - Web Category Exemptions: Excludes entire FortiGuard categories [cite: 9, 10].
 - Address / FQDN Exemptions: Bypasses inspection for explicit host objects or subnets [cite: 9, 10].
 - Reputable Websites: Dynamically exempts an allowlist of trusted corporate domains maintained and updated continuously by FortiGuard [cite: 9].
-

9.) Antivirus & Malware Defense

a) Scan Modes: Flow-based stream scanning vs. proxy-based full-file buffering. b) Virus Databases: Normal, Extended, and Extreme threat detection engines. c) Advanced Mitigation: Outbreak prevention heuristics and FortiSandbox integration.

9.) Antivirus & Malware Defense

a) Scan Modes (Flow-Based Stream Scanning vs. Proxy-Based Full-File Buffering)

- Flow-Based Inspection (Default Mode):
 - Inspects content on-the-fly as packets pass through the FortiGate, prioritizing traffic throughput [cite: 3, 7, 8].
 - Uses a hybrid stream-based technique where the IPS engine caches incoming packets while simultaneously forwarding them to the destination [cite: 9, 10].
 - The Last-Packet Hold: FortiGate holds the final packet of a stream in buffer memory while the antivirus engine finishes scanning the assembled payload [cite: 10].
 - *Clean Result*: The final packet is released, and the download completes seamlessly [cite: 10].
 - *Infected Result*: FortiGate drops the final packet and sends a TCP Reset (RST), leaving the recipient with a truncated, unopenable file [cite: 10, 18]. Because initial packets were already delivered, a block replacement page cannot be displayed on the first attempt [cite: 10, 18]. However, FortiGate caches the URL/hash so subsequent download attempts display an instant block page [cite: 10, 18].
- Proxy-Based Inspection:
 - Terminates the connection and buffers the entire file in memory before executing the antivirus scan [cite: 3, 14, 19].
 - *Clean Result*: Releases the file to the client [cite: 14, 19].
 - *Infected Result*: Prevents all file packets from reaching the endpoint and delivers a clean HTTP Block Replacement Page [cite: 14, 17].
 - *Resource Constraint*: Requires higher memory (RAM) allocation (>2 GB) [cite: 15].
- Client Comforting:
 - Configurable in proxy-based mode for HTTP and FTP traffic (config firewall profile-protocol-options) [cite: 14].
 - Transmits a tiny trickle of data to the client browser while the proxy buffers large files [cite: 14, 19]. This keeps the connection alive and prevents browser timeout errors during long scans [cite: 14, 19].
- Protocol & Advanced Feature Differences:
 - Flow-based mode handles standard web and mail protocols (HTTP, HTTPS, FTP, SMTP, POP3, IMAP) [cite: 11].

- Proxy-based mode is required for advanced protocols (MAPI and SSH) [cite: 15], Content Disarm and Reconstruction (CDR) [cite: 15], and FortiNDR inspection [cite: 15].

b) Virus Databases & Detection Engines

- Signature-Based Detection: Uses FortiGuard Content Pattern Recognition Language (CPRL) signatures to match known malicious code [cite: 4, 6].
- Database Types:
 1. Extended Database: The standard signature package installed on most FortiGate models to catch active, circulating wild threats [cite: 8].
 2. Extreme Database: An expanded, highly comprehensive signature database covering obscure, historical, and legacy malware threats [cite: 8, 13]. Activated via CLI on supported hardware (`set use-extreme-db`) [cite: 8, 13].
- Scanning Order & Techniques: When all detection techniques are enabled in an antivirus profile, FortiGate scans files in a strict 3-step sequence [cite: 6]:
 1. Antivirus Scan: Compares files against the standard signature database for exact pattern matches [cite: 5, 6].
 2. Grayware Scan: Identifies Potentially Unwanted Programs (PUPs) and Potentially Unwanted Applications (PUAs) installed without user consent [cite: 5, 6].
 3. Artificial Intelligence (AI) Scan: Uses a machine-learning engine trained by FortiGuard Labs to detect zero-day malware in Windows Portable Executable (PE) files [cite: 5, 6]. Zero-day threats identified by the AI engine are flagged with the signature `W32/AI.Pallas.Suspicious` [cite: 5].

c) Advanced Mitigation, Threat Feeds & FortiSandbox Integration

- FortiGuard Virus Outbreak Protection Service (VOS):
 - Supplements local signatures by querying FortiGuard's Global Threat Intelligence database with the real-time hash of a scanned file [cite: 6].
 - Allows blocking newly emerging malware outbreaks hours before formal signature packages are built and downloaded [cite: 6].
- Malware Hash Lookup Hierarchy: When external threat feeds are configured in an antivirus profile, FortiGate checks file hashes in the following order [cite: 6]:
 - Local Antivirus Signature Database [cite: 6]
 - EMS Threat Feed (Dynamic threat feeds pushed from FortiClient EMS) [cite: 6]
 - External Malware Block List (Plaintext HTTP/HTTPS lists of MD5, SHA1, or SHA256 hashes) [cite: 6]
 - FortiGuard Outbreak Prevention Database [cite: 6]
- FortiSandbox Integration:
 - Unrated or suspicious zero-day files are sent to an on-premises FortiSandbox appliance or FortiSandbox Cloud for dynamic execution inside isolated virtual machine sandboxes [cite: 24].

- *Verdict Feedback*: If FortiSandbox determines a file is malicious, it updates FortiGate's local cache and shares the hash threat intelligence across the Security Fabric.
-

10.) Web Filtering

a) FortiGuard Categories: Category-based blocking, monitoring, and usage quotas. b) Static URL Filtering: Exact match, wildcard, and regular expression pattern matching. c) Web Rating Overrides: Modifying domain/FQDN category classification using host-only syntax ([example.com](#) or [www.example.com](#)). d) Client Response: Customizing replacement block pages and proxy web overrides.

10.) Web Filtering

a) FortiGuard Categories & Category Action Types

- Category-Based Filtering: Instead of managing individual URLs, FortiGate queries the FortiGuard Distribution Network (FDN) to determine a website's assigned category (e.g., *Malicious Websites*, *Social Networking*, *Streaming Media*) and enforces security actions based on that rating [cite: 8].
- Category Actions:
 - Allow: Permits traffic seamlessly without generating log entries [cite: 9].
 - Monitor: Permits traffic while generating detailed web filter security log entries [cite: 9].
 - Block: Denies access immediately and displays an HTTP block replacement page to the user [cite: 9].
 - Warning: Blocks initial access and displays a warning replacement page containing a Proceed button [cite: 9, 10]. If the user clicks "Proceed", access is granted for a configurable warning interval, and a "passthrough" log entry is recorded [cite: 10].
 - Authenticate: Blocks initial access until the user enters valid credentials (local account, LDAP, or RADIUS) on an HTTP replacement page [cite: 9, 10]. Users matching the authorized group are granted access for a set authentication interval [cite: 10].
- Category Usage Quotas:
 - Allows administrators to limit daily access to specific categories based on Total Time (hours/minutes) or Total Traffic Volume (MB/GB) [cite: 11].
 - Daily quotas reset automatically at midnight [cite: 11].
 - *Proxy-Based Requirement*: Quotas can be applied to Monitor, Warning, and Authenticate actions, but are available strictly when the policy is set to Proxy-based inspection mode [cite: 11].

b) Static URL Filtering

Static URL filtering provides explicit control over specific domain patterns and URLs before FortiGuard category queries occur [cite: 13].

- Pattern Types:
 - Simple: Matches exact domain or path strings (e.g., `www.example.com/folder`) [cite: 13, 14].
 - Wildcard: Uses asterisk (*) wildcards to match variable domain patterns (e.g., `*.somewhere.com`) [cite: 13, 14].
 - Regular Expression: Uses standard regex formatting for advanced string matching (e.g., `.*\something\.(org|biz)`) [cite: 13, 14].
- Processing Logic: Evaluated in a strict top-to-bottom sequence. Matching halts on the first rule match [cite: 13].
- Static URL Filter Actions:
 - Exempt: Bypasses ALL subsequent security profile inspections (including FortiGuard web filtering, antivirus, and IPS) for trusted sites [cite: 13, 14].
 - Block: Explicitly denies access and displays a block page [cite: 13, 28].
 - Allow: Permits the URL match, but passes the connection down the chain for further inspection (FortiGuard categories, content filtering, and antivirus) [cite: 13].
 - Monitor: Passes the connection down the chain while recording a log entry [cite: 13].

c) Web Rating Overrides

- Reclassifying Site Ratings: Allows administrators to override the FortiGuard category classification for a specific domain without waiting for an official re-rating from FortiGuard Labs [cite: 12].
- Syntax Constraints:
 - Accepts domain / FQDN strings only (e.g., `example.com` or `www.example.com`).
 - *Invalid Syntax*: Does not accept URL paths (e.g., `example.com/index.html`) or port numbers (e.g., `example.com:443`). Sub-path filtering must be handled via Static URL Filters instead.
- Custom Categories: Overridden URLs can be assigned to standard FortiGuard categories or mapped to custom local categories defined under `Security Profiles > Web Rating Overrides` [cite: 12].

d) Internal Web Inspection Order & Rating Caching

- Pipeline Sequence: Within a Web Filtering profile, inspection occurs in a strict 3-step sequence [cite: 14]:
 - Static URL Filter (Matches top-to-bottom) [cite: 14]

- FortiGuard Category Filter (Queries FDN or local cache) [cite: 14]
- Advanced Filters (SafeSearch enforcement, HTTP POST blocking, ActiveX/Java script removal) [cite: 14]
- *Cross-Profile Ordering Rule*: In FortiOS, Application Control is evaluated before Web Filtering [cite: 21, 22]. Because Application Control runs first, a Static URL Filter "Exempt" action inside a web profile cannot bypass Application Control rules [cite: 22].
- *Grace Period & Rating Errors*:
 - Active FortiGuard contracts include a 2-day grace period upon expiration [cite: 8]. After two days, rating queries return a "rating error" [cite: 8].
 - By default, FortiGate blocks traffic when a rating error occurs, unless "Allow websites when a rating error occurs" is explicitly enabled in the web profile settings [cite: 7, 8].
- *Web Rating Cache*: Stores recent domain ratings in FortiGate RAM memory to speed up classification and minimize WAN latency [cite: 15].

e) Client Response & Replacement Messages

- *Custom Block Pages*: HTML block pages displayed to users when a website is blocked by Static URL filters, FortiGuard categories, or Quota limits can be fully customized under **System > Replacement Messages** [cite: 10].
- *UUID Traceability*: Replacement pages include the Universal Unique Identifier (UUID) of the specific firewall policy that triggered the block, enabling rapid administrative troubleshooting in multi-policy enterprise environments [cite: 20].

11.) Application Control & Intrusion Prevention System (IPS)

a) Application Control: Deep packet application signature matching, categories, and actions (Allow, Monitor, Block). b) IPS Sensors: Signature-based vulnerability matching, rate-based anomaly detection, and protocol decoders. c) IPS Tuning: Filtering IPS sensors by severity, target OS, and performance impact.

11.) Application Control & Intrusion Prevention System (IPS)

a) Application Control Architecture & Mechanics

- *Layer 7 Deep Packet Inspection (DPI)*: Application Control identifies network applications based on behavioral data pattern matching and signature analysis rather than relying on transport-layer port numbers (e.g., detecting BitTorrent or Skype running over standard TCP port **80** or **443**).
- *Application Attributes & Classification*:

- Categories: Grouped into functional types such as *Social.Media*, *Video/Audio*, *Game*, *P2P*, *Business*, and *Collaboration*.
- Risk Levels: Rated on a scale from 1 (Low) to 5 (Critical) based on threat potential, bandwidth consumption, and data leakage risks.
- Technologies: Classifies underlying delivery mechanics (e.g., *Browser-based*, *Client-Server*, *Network.Service*, *Peer-to-Peer*).
- Application Control Actions:
 - Allow: Permits application traffic through without generating logs.
 - Monitor: Permits application traffic while recording security log entries.
 - Block: Drops application packets silently.
 - Reset: Drops application packets and actively transmits a TCP Reset (**RST**) packet to both client and server to close socket connections immediately.
 - Quarantine: Blocks the application and dynamically isolates the initiating client's source IP address for a configurable time duration.

b) Application Control Configuration & Pipeline Order

- Filters vs. Application Overrides:
 - Category / Risk Filters: Apply broad action rules across entire categories or risk tiers.
 - Application Overrides: Explicit rules targeting individual specific applications (e.g., blocking *Facebook.Video* while allowing *Facebook.Base*). Overrides take precedence over category-level filters.
- CRITICAL PIPELINE EVALUATION ORDER:
 - In the FortiOS security profile chain, Application Control is evaluated BEFORE Web Filtering.
 - *The Exam Gotcha*: Because Application Control runs first, configuring an "Exempt" action inside a Static URL Filter within a Web Filter profile cannot bypass Application Control rules.

c) Intrusion Prevention System (IPS) Mechanics & Sensors

- Signature-Based Inspection: Inspects transient traffic payloads against known exploit patterns, vulnerability triggers, buffer overflow attempts, and malware command-and-control (C2) communication protocols.
- IPS Sensors: Custom collections of IPS rules applied to firewall policies. Signatures within a sensor are organized and filtered using specific criteria:
 - Severity: *Critical*, *High*, *Medium*, *Low*, *Info*.
 - Target OS: *Windows*, *Linux*, *macOS*, *Android*, *iOS*, *Router/Switch*.
 - Protocols: *HTTP*, *FTP*, *SMB*, *DNS*, *SSH*, *MS-RPC*.
- IPS Actions:
 - Default: Executes the official default action defined by FortiGuard Labs for that specific signature.
 - Pass / Allow: Ignores signature matches and forwards traffic.
 - Monitor: Permits traffic while logging matches.

- Block: Drops matching attack packets.
 - Reset: Drops packets and sends a TCP **RST** frame to break connection sockets.
- Packet Logging: Enabling **set packet-log enable** inside an IPS sensor rule captures raw payload frames matching signature triggers for forensic analysis.

d) Rate-Based Anomaly Detection & DoS Policies

- Anomaly Detection: Identifies protocol violations and abnormal traffic volume spikes (e.g., SYN floods, ICMP sweeps, UDP floods, port scans) that do not match traditional static signatures.
- Denied Traffic DoS Protection (**config firewall DoS-policy**):
 - Evaluated at the physical interface layer BEFORE standard firewall policy processing.
 - Drops volumetric denial-of-service flood traffic at the ingress boundary, preventing malicious traffic from consuming firewall CPU and session table memory.

e) Performance Tuning & Hardware Acceleration

- The IPS Daemon (**ipsengine**): A core system process responsible for executing pattern matching for IPS, Application Control, Flow-based Antivirus, and Flow-based Web Filtering.
- Hardware Acceleration (CP9 & NTurbo):
 - CP9 Content Processor: Offloads complex cryptographic operations and signature pattern-matching tasks away from the primary system CPU.
 - NTurbo: Offloads flow-based IPS packet scanning directly to specialized Network Processors (NP6/NP7), achieving near line-rate throughput on hardware-accelerated interfaces.
- IPS Database Options:
 - Standard Database: Default lightweight package optimized for performance and active threats.
 - Extended Database: High-density database covering legacy, obscure, and low-risk vulnerabilities (**config system global \(\rightarrow\) set ips-db-extended**).

12.) IPsec VPN

a) IKE Phase 1 Negotiation: Peer authentication, DH key exchange groups, and proposal parameters. b) IKE Phase 2 Negotiation: Proxy ID match requirements, IPsec SAs, and Perfect Forward Secrecy (PFS). c) Topologies: Site-to-site route-based IPsec tunnels, dial-up VPNs, and redundant mesh setups. d) Diagnostics: Reviewing **diagnose vpn ike gateway list** (Phase 1) and **diagnose vpn tunnel list** (Phase 2 traffic counters).

12.) IPsec VPN

a) IKE Phase 1 Negotiation

- Purpose: Authenticates remote peers and establishes a secure, encrypted control channel (the IKE SA) to negotiate Phase 2 parameters [cite: 1]. The IKE SA is bidirectional, using the exact same session key to encrypt and decrypt traffic flowing in both directions [cite: 1].
- Peer Authentication Methods:
 - Pre-shared Key (PSK): Both peers must be configured with an identical, case-sensitive secret key [cite: 3, 17].
 - Digital Signature (Certificates): Authenticates peers using X.509 digital certificates. The local peer validates the remote peer's signature using the corresponding Root/Intermediate CA certificate installed in its local store [cite: 3].
 - Extended Authentication (XAuth): Adds a secondary layer of user-level authentication (prompting for username and password against LDAP/RADIUS) during Phase 1 negotiation [cite: 1, 5].
- IKE Versions & Exchange Modes:
 - IKEv1: Supports two exchange modes [cite: 1, 3]:
 - Main Mode: Uses 6 message exchanges [cite: 1]. Encrypts peer identities, offering higher security at the cost of slower negotiation [cite: 3]. Requires static IP addresses on both ends [cite: 3].
 - Aggressive Mode: Uses 3 message exchanges [cite: 1, 3]. Faster negotiation, but transmits peer identities in clear-text [cite: 3]. Mandatory for dial-up or dynamic IP environments where peer identity must be evaluated before selecting the pre-shared key [cite: 3, 5].
 - IKEv2: Streamlines negotiation into 4 messages, natively supports NAT-Traversal (NAT-T), and eliminates Main and Aggressive modes entirely [cite: 3].
- Phase 1 Proposals & Parameters:
 - Encryption & Authentication: Pairs encryption algorithms (AES-128, AES-256, DES, 3DES) with hash algorithms (SHA-1, SHA-256, SHA-512) [cite: 3, 4].
 - Diffie-Hellman (DH) Groups: Mandatory for key exchange during Phase 1 [cite: 4]. Higher DH group numbers (e.g., DH 14, 19, 20, 21) provide stronger mathematical protection against key cracking, but require longer CPU compute time [cite: 4].
- Dead Peer Detection (DPD): Continuously monitors tunnel availability by sending periodic keepalive probes [cite: 2, 16]. The default mode is On Demand, which reduces polling overhead compared to "On Idle" [cite: 2].

b) IKE Phase 2 Negotiation

- Purpose: Negotiates IPsec SAs protected inside the secure Phase 1 IKE SA channel [cite: 5]. Unlike Phase 1, Phase 2 generates two unidirectional SAs: one dedicated key to encrypt outbound traffic and a separate key to decrypt inbound traffic [cite: 5].
- Phase 2 Protocols:
 - Encapsulating Security Payload (ESP): Provides data confidentiality (encryption), payload authentication, and integrity check values [cite: 5].
 - Authentication Header (AH): Provides source authentication and data integrity, but does not provide payload encryption [cite: 5].
- Proxy IDs / Quick Mode Selectors:
 - Defines the specific local and remote subnets, protocols, and transport ports authorized to pass through the tunnel [cite: 6, 7].
 - *Match Requirement*: In point-to-point site-to-site tunnels, Proxy IDs on both peers must match exactly (or be a complete subset) [cite: 7, 17]. A mismatch in subnets or ports triggers a **TS_UNACCEPTABLE** negotiation failure [cite: 17].
- Perfect Forward Secrecy (PFS): When enabled, FortiGate executes a fresh Diffie-Hellman exchange every time Phase 2 key lifetime expires [cite: 6, 7]. This ensures new session keys are not derived from old keys, protecting past session data if a key is ever compromised [cite: 6].
- Hardware Acceleration (NPU Offloading): Network Processors (NP6/NP7) offload IPsec encryption/decryption tasks [cite: 8, 10]. Modern algorithms like **CHACHA20POLY1305** are not hardware-offloaded by NP units and run on the main CPU [cite: 8].

c) Topologies & Routing

- Route-Based IPsec VPN (Standard FortiOS Deployment):
 - Automatically creates a virtual IPsec interface (**tun_name**) in the FortiGate network configuration [cite: 9, 11].
 - Traffic entering the tunnel is governed strictly by routing decisions (static routes or dynamic routing protocols like BGP/OSPF pointing to the virtual IPsec interface as the egress target) [cite: 9].
 - Allows applying standard UTM security profiles (Antivirus, IPS, Web Filtering) directly within firewall policies [cite: 10, 18].
- Dial-Up VPN:
 - FortiGate acts as a central hub (responder) accepting dynamic incoming tunnel connections from remote spokes or mobile FortiClient endpoints [cite: 5, 9].
 - When **add-route** is disabled on a dial-up gateway, static routes are omitted, allowing dynamic routing protocols (BGP/OSPF) to dynamically advertise spoke subnets over the tunnel [cite: 9].

d) Diagnostics & Troubleshooting Commands

Phase 1 Control Plane Inspection:

diagnose vpn ike gateway list name <Tunnel_Name>

- Displays Phase 1 IKE SA status, established uptime, IKE version, peer IP addresses, and active DPD mode [cite: 11, 16]. **established 1/1** indicates a healthy Phase 1 session [cite: 16, 19].

Phase 2 Data Plane Inspection & Traffic Counters:

`diagnose vpn tunnel list name <Tunnel_Name>`

OR

`get vpn ipsec tunnel details`

- Displays Phase 2 IPsec SAs, SPI key hashes, Quick Mode selectors, MTU settings, and real-time **rxp** (received packets) and **txp** (transmitted packets) counters [cite: 10, 11, 16].
 - *Triage Rule:* If **txp** > 0 and **rxp** = 0, FortiGate is encrypting and sending packets out, but receiving no return traffic from the remote peer [cite: 16]. Check remote firewall policies and return routing [cite: 16, 18].

Real-Time IKE Debugging:

`diagnose debug application ike -1`

`diagnose debug enable`

- *Common Error Interpretations* [cite: 17]:
 - **NO_PROPOSAL_CHOSEN:** Mismatch in Phase 1 or Phase 2 proposal parameters (encryption, hash, DH group, or key lifetime) [cite: 17].
 - **AUTHENTICATION_FAILED:** Pre-shared key mismatch or certificate trust failure [cite: 17].
 - **TS_UNACCEPTABLE:** Traffic selector / Proxy ID mismatch (local or remote subnet definitions do not align) [cite: 17].
 - **INVALID_ID_INFORMATION:** Peer identifier mismatch [cite: 17].

Clearing Active Sessions:

`diagnose vpn ike gateway clear name <Tunnel_Name>`

- Resets the Phase 1 IKE SA for the specified tunnel [cite: 11, 12].
 - **CRITICAL WARNING:** Omitting the tunnel name (`diagnose vpn ike gateway clear`) clears all active IKE SAs globally across every VDOM on the device [cite: 11].

13.) SSL VPN

- a) Deployment Modes: Web Portal mode (bookmark proxies) vs. Tunnel Mode (virtual adapter).
b) Client Verification: Host check posture evaluation and OS checks. c) Access Control: Client realms, split tunneling configurations, and user group bindings.
-

13.) SSL VPN

a) Deployment Modes

- Web Portal Mode (Agentless / Clientless):
 - Operates completely agentless via a standard web browser over HTTPS [cite: 23].
 - Users log in to a customizable FortiGate web portal and access internal web applications, file shares (SMB), RDP, and SSH sessions using built-in bookmark proxies [cite: 70].
 - *Mechanics*: FortiGate acts as a reverse proxy, translating and rewriting client browser requests before forwarding them to backend servers.
 - *Limitation*: Supports only specific application types configured via bookmarks; non-web applications and custom IP protocols cannot traverse Web Portal mode.
- Tunnel Mode (Agent-Based):
 - Requires installing FortiClient endpoint software on the user's device [cite: 25].
 - *Mechanics*: FortiClient creates a virtual network adapter (`sslvpn` interface) on the client OS [cite: 46]. FortiGate assigns an IP address from a virtual IP pool to the client virtual adapter [cite: 46].
 - Provides full, transparent Layer 3 network connectivity, allowing any IP-based application to pass securely through the encrypted TLS tunnel [cite: 25, 46].

b) Client Verification & Host Checks

- OS & Browser Verification: FortiGate can evaluate the remote endpoint's operating system version and browser build during initial connection establishment before granting access.
- Host Check Posture Evaluation:
 - Evaluates client security posture (verifying active Antivirus software, Firewall state, dynamic registry keys, or process file hashes).
 - *Action Types*: Can enforce strict compliance (blocking endpoints that fail health checks) or dynamically assign non-compliant users to restricted web portals.
- Client Certificates (PKI): Enforces mutual TLS authentication requiring the client browser or FortiClient to present a valid user X.509 certificate signed by a trusted enterprise CA.

c) Access Control & Traffic Steering

- Client Realms (`config vpn ssl web realm`):

- Enables creating custom login URL paths (e.g., <https://vpn.company.com/contractors> vs. <https://vpn.company.com/employees>).
- Custom realms allow binding different user groups, portals, and authentication options to separate URL entry points on the same FortiGate listening interface.
- Split Tunneling Mechanics:
 - Disabled (Full Tunneling): All client IP traffic (including public internet browsing) is routed through the SSL VPN tunnel to FortiGate [cite: 69]. FortiGate inspects and enforces security profiles on all internet-bound traffic before forwarding it [cite: 69].
 - Enabled (Split Tunneling): Only traffic destined for explicitly defined internal corporate subnets is routed through the VPN tunnel [cite: 62]. All other internet traffic exits directly through the user's local ISP, preserving FortiGate processing resources and WAN bandwidth [cite: 62].
- User Group Bindings ([config vpn ssl settings](#)):
 - Maps specific User Groups or IP pools to specific SSL VPN Portals (e.g., mapping [Admins](#) to [full-access-portal](#) and [Contractors](#) to [web-only-portal](#)).
 - *Firewall Policy Requirement*: SSL VPN traffic must be permitted by an active firewall policy with incoming interface set to [ssl.root](#) (or the VDOM's SSL VPN interface) and source address set to the SSL VPN virtual IP range and user group.

d) Diagnostics & Troubleshooting Commands

Inspect Active SSL VPN Users & Sessions:

`diagnose vpn ssl list`

- Displays active connections, assigned virtual IPs, user groups, connection duration, and real-time byte counters [cite: 46].

View SSL VPN System Statistics:

`diagnose vpn ssl statistics`

- Displays active session counts against license limits, breaking down sessions into Tunnel vs. Web mode [cite: 46].

Real-Time SSL VPN Daemon Tracing:

`diagnose debug application sslvpn -1`

`diagnose debug enable`

- Traces authentication handshakes, portal assignment, split tunneling route pushes, and disconnect errors in real time [cite: 46].

- *Strategic Deprecation Note:* Fortinet has announced the gradual transition away from traditional SSL VPN features in FortiOS 7.4+ releases in favor of ZTNA (Zero Trust Network Access) and IPsec remote access with FortiSASE [cite: 23, 26, 46].
-

14.) High Availability (FGCP Cluster)

a) Cluster Modes: Active-Passive (failover redundancy) vs. Active-Active (UTM processing distribution). b) HA Mechanics: Dedicated heartbeat interfaces, virtual MAC address generation, and primary unit election logic. c) Session Failover: Session synchronization for stateful connection persistence. d) Maintenance: In-band HA management interfaces and seamless cluster firmware upgrades.

14.) High Availability (FGCP Cluster)

a) Cluster Modes (Active-Passive vs. Active-Active)

FortiGate Clustering Protocol (FGCP) links two or more identical FortiGate devices into a single logical cluster for redundancy and session persistence [cite: 29].

- **Active-Passive (A-P) Mode (Default & Most Common):**
 - Only the Primary unit actively processes network traffic and handles security profile inspection [cite: 30].
 - Secondary (standby) devices process no traffic [cite: 30]. They continuously receive configuration and session synchronization updates across heartbeat interfaces while monitoring the health of the primary unit [cite: 29, 31, 39].
 - *Failover Impact:* If the primary fails, a secondary unit immediately takes over the primary role with zero-to-minimal traffic disruption [cite: 31].
- **Active-Active (A-A) Mode:**
 - All cluster members actively process network traffic [cite: 32].
 - The primary unit receives all incoming connections first and acts as a session proxy/distributor, offloading supported security profile inspection (UTM processing) to secondary members [cite: 32, 38].
 - *Primary Role:* The primary unit continues to handle all routing, session lookup, and non-UTM processing [cite: 32]. If a secondary node fails, the primary reassigns its traffic sessions to remaining cluster members [cite: 32].

b) HA Mechanics, Heartbeats & Virtual MAC Addresses

- **Heartbeat Interfaces:**
 - Members communicate, discover peers, and exchange **hello** packets over dedicated physical Heartbeat Interfaces [cite: 29, 30, 37].

- *Best Practice*: Administrators should configure at least two heartbeat links connected directly or across the same Layer 2 broadcast domain for redundancy [cite: 33].
- Default Heartbeat Parameters: Heartbeat interval = 200 ms; Heartbeat lost threshold = 10 (declares a peer dead if 10 consecutive heartbeats are missed, i.e., 2 seconds) [cite: 62].
- Virtual MAC (VMAC) Address Generation:
 - Upon cluster formation, FGCP automatically assigns a unique Virtual MAC address to each physical and logical data interface across cluster members [cite: 47].
 - Format: `00-09-0f-09-<Group_ID_Hex>-<Interface_Index_Hex>`.
 - *Failover Gratuitous ARP*: When a failover occurs, the new primary unit inherits the exact same Virtual MAC addresses on its interfaces and immediately broadcasts Gratuitous ARP (GARP) frames to upstream and downstream switches [cite: 47]. This instructs connected switches to update their MAC address tables to point to the new primary unit's physical switch port, eliminating the need for endpoints to flush ARP caches [cite: 47].
 - *Management Exception*: Reserved HA management interfaces keep their physical factory MAC addresses and do not adopt virtual MACs [cite: 47].

c) Primary Unit Election Sequence

When cluster nodes boot up or a failover occurs, FGCP evaluates election criteria sequentially. The process halts on the first criteria that successfully selects a winner [cite: 34].

- Override Disabled (Default Non-Preemptive Sequence) [cite: 34, 71, 72]:
 - Connected Monitored Interfaces: The member with the highest number of active, operational monitored interfaces (`monitor` ports) wins [cite: 35, 71].
 - HA Boot Uptime: The member with the higher HA uptime by at least 5 minutes (300 seconds) wins [cite: 35, 71, 72]. This prevents flapping/preemption if a rebooted primary comes back online [cite: 72].
 - Device Priority: The member with the higher priority value (`1-255`; higher number wins) [cite: 35, 71].
 - Serial Number: The member with the lexicographically highest serial number wins [cite: 35, 71].
- Override Enabled (`set override enable`) (Preemptive Sequence) [cite: 72]:
 - Connected Monitored Interfaces [cite: 71, 72]
 - Device Priority (*Bypasses HA Boot Uptime entirely*) [cite: 72]
 - HA Boot Uptime [cite: 35]
 - Serial Number [cite: 35]

- *Operational Impact*: With override enabled, if an offline primary with a higher configured priority boots up, it preempts the current active secondary and reclaims the primary role immediately [cite: 72].

d) Session Synchronization & Failover Triggers

- Failover Trigger Types:
 - Device Failover: Loss of heartbeat packets from the primary unit [cite: 44].
 - Link Failover: Failure or physical link disconnect on one or more monitored interfaces on the primary [cite: 44].
 - Remote Link Failover: Failure of link health monitors tracking remote beacon gateways [cite: 45].
 - Memory / SSD Failover: Memory utilization exceeding configured conserve thresholds or file-system corruption detected on an SSD disk [cite: 45].
- Session Synchronization (`set session-pickup enable`):
 - Replicates active TCP session tables across the heartbeat link to secondary units [cite: 38, 72].
 - *Supported Sessions*: Standard IPv4/IPv6 TCP, UDP, ICMP, and IPsec SA sessions [cite: 29, 37].
 - *Unsynchronized Sessions*: Sessions terminating directly on the FortiGate itself (e.g., active SSL VPN user sessions, explicit web proxy connections, and management GUI/SSH sessions) cannot be synchronized and must be re-established after a failover [cite: 46].

e) Unsynchronized Configuration Settings

While complete configuration files are automatically synchronized from primary to secondary members, the following settings are explicitly exempt from synchronization [cite: 29, 43]:

1. HA Device Priority (`priority`) [cite: 37, 43]
2. HA Override Setting (`override`) [cite: 37, 43]
3. FortiGate Hostname (`hostname`) [cite: 37, 43]
4. Reserved HA Management Interface IPs & Routes [cite: 43]
5. In-Band HA Management IP Addresses [cite: 43]
6. Ping Server HA Priorities [cite: 43]
7. Licenses (FortiGuard, FortiCloud, and FortiCare contracts—except FortiToken serial numbers) [cite: 33, 43]

f) Maintenance, Diagnostics & Management

Checksum Verification:

```
diagnose sys ha checksum show
```

- Calculates cryptographic hashes for `global`, `root`, and `all` configuration scopes across cluster members [cite: 50, 63, 72]. Identical hash values confirm the cluster is in-sync [cite: 50, 72].
- Cluster Resynchronization: If checksums differ (`in-sync: no`), force a manual resynchronization from the primary CLI using `execute ha synchronize start` [cite: 63, 72].

CLI Tunneling (`execute ha manage`): Allows an administrator logged into the primary unit's CLI to establish an internal SSH tunnel directly to a secondary unit's CLI over the heartbeat interface without needing a separate physical serial console cable [cite: 51, 63]:

```
execute ha manage <member_index> <admin_username>
```

Manual Failover Execution: When HA override is disabled, administrators can force a non-disruptive failover by resetting the primary unit's HA uptime counter to zero [cite: 35]:

```
diagnose sys ha reset-uptime
```

15.) System Diagnostics & Troubleshooting

a) Real-Time Packet Traces: Running `diagnose debug flow` to inspect routing, policy evaluation, and packet drops. b) Packet Sniffing: Capturing raw frames using `diagnose sniffer packet`. c) System Performance: Identifying resource hogs using `diagnose sys top` and matching daemons (`ipsengine`, `scanunitd`, `sslvpn`, `httpsd`). d) Memory Conserve Mode: Threshold triggers, system conserve actions, and triage using `diagnose hardware sysinfo conserve`. e) Layer 1/2 Physical Triage: Link speed, duplex mismatches, and CRC error monitoring (`get system interface physical`).

15.) System Diagnostics & Troubleshooting

a) Real-Time Packet Traces (`diagnose debug flow`)

- Purpose & Value: The `diagnose debug flow` utility traces a packet step-by-step through every internal kernel engine inside FortiGate (routing lookup, firewall policy evaluation, NAT, UTM profiles, and IPsec/SSL VPN processing). When a packet is dropped, debug flow output identifies the exact processing stage and reason for the drop.
- CPU Safety Warning: Debug flow captures matching packets in real-time on the CPU. Always configure a specific filter before starting a trace on a production firewall to prevent CPU overload.

Complete CLI Execution Sequence:

1. Clear previous debug filters and state

diagnose debug reset

diagnose debug disable

2. Configure target packet filter (IP, port, or protocol)

diagnose debug flow filter addr 192.168.10.5

diagnose debug flow filter port 443

diagnose debug flow filter proto 6 # 6=TCP, 17=UDP, 1=ICMP

3. Enable descriptive function names and rule matching

diagnose debug flow show function-name enable

diagnose debug flow show iprope enable

4. Start the trace with a limited packet count (e.g., 10–20 packets)

diagnose debug flow trace start 10

5. Enable global debug output

diagnose debug enable

6. ALWAYS DISABLE AND RESET IMMEDIATELY WHEN DONE

diagnose debug disable

diagnose debug flow trace stop

diagnose debug reset

-
- Interpreting Trace Drop Output:
 - **no matching route**: The routing table contains no active FIB path to the target destination.

- **Allowed by Policy-1: SNAT**: Successfully matched Firewall Policy ID 1 and applied Source NAT.
- **Denied by Policy-5 or result-deny**: Matched an explicit Deny rule or was dropped by the Implicit Deny policy.

b) Packet Sniffing (**diagnose sniffer packet**)

- Interface Packet Capture: Functions equivalently to **tcpdump**, capturing raw frames at the physical or logical interface level before or after firewall policy processing.

Syntax Structure:

diagnose sniffer packet <interface> '<filter>' <verbose> <count> <tsformat>

- - Interface: Specific port name (e.g., **port1**, **lan**), **ssl.root**, or **any** (captures across all physical and logical interfaces simultaneously).
 - Filter: Standard Berkeley Packet Filter (BPF) syntax (e.g., '**host 10.0.1.10 and port 80**').
 - Verbose Levels:
 - **1**: IP header only.
 - **2**: IP header + IP payload.
 - **3**: IP header + IP payload + Layer 2 Ethernet headers.
 - **4**: IP header + Interface names.
 - **6**: IP header + IP payload + Ethernet headers + Interface names (PCAP export level).
 - Timestamp Format (**tsformat**): **a** = Absolute UTC time; **l** = Local system time.
- **Dropped Packets Alert**: If the output displays **X packets dropped by kernel**, the sniffer filter buffer overflowed. Apply a narrower filter to prevent missing frames.

c) System Performance & Process Monitoring

- Global System Health (**get system performance status**): Displays real-time CPU usage, total/used RAM percentage, current active session counts, session setup rates, and hard disk status.
- Process Inspection (**diagnose sys top**):
 - Displays active system daemons sorted by CPU or Memory usage.
 - Sorting Shortcuts: Press **Shift + P** to sort by CPU usage; press **Shift + M** to sort by Memory (RAM) usage.
- Key Daemons to Recognize:
 - **ipsengine**: Flow-based inspection, Application Control, and IPS pattern matching.
 - **scanunitd**: Proxy-based Antivirus file scanning.
 - **wad**: Web proxy, WAN optimization, and proxy-based Web Filtering.

- `sslvpn`: SSL VPN connection handler.
- `miglogd`: System log writing and remote export process.

d) Memory Conserve Mode

FortiGate enforces a self-protection mechanism when system memory (RAM) usage crosses defined threshold limits to prevent kernel crashes:

- Configurable Thresholds (`config system global`):
 - Red Threshold (Default 88%): FortiGate enters Conserve Mode. The GUI displays a red warning banner. System configuration changes are blocked, quarantine/FortiSandbox actions are skipped, and proxy-based UTM inspection is bypassed or dropped.
 - Extreme Threshold (Default 95%): Absolute self-preservation state. All new incoming sessions are dropped outright.
 - Green Threshold (Default 82%): Recovery threshold. Memory must fall below this percentage for FortiGate to exit Conserve Mode and resume normal operation.
- IPS Fail-Open Setting (`config ips global`):
 - `set fail-open enable`: Permits uninspected packets to pass through during high memory/conserve mode states.
 - `set fail-open disable` (Default): Drops new incoming sessions when the IPS engine runs out of memory buffers.

Verification Command:

`diagnose hardware sysinfo conserve`

- Displays active Conserve Mode status (`on/off`), current RAM usage in MB/percentage, and active threshold limits.

e) Layer 1/2 Physical Triage

Physical Interface State:

`get system interface physical`

- Displays physical media link status (`up/down`), negotiated speed (e.g., 1000Mbps), duplex mode (`full/half`), and hardware statistics.
 - CRC & Duplex Mismatches: High counts of CRC errors, frame alignment errors, or collision spikes indicate faulty Ethernet cabling, damaged transceivers (SFP/SFP+), or speed/duplex negotiation mismatches on upstream switch ports.
-